

Understanding Zero Trust Networks

What is Zero Trust network security?

Imagine you live in a big house with many rooms, and in each room, you have valuable things like your personal and financial documents, your private correspondence and expensive belongings. Now, imagine that instead of just locking the front door of the house, you decide to put a lock or a keypad on every single door to every room. This way, even if someone somehow gets into your house, they can't get into your room or your children's rooms unless they have the key for each specific room. This is similar to how a zero trust network operates.

In a traditional network, once you're inside, you can freely access different areas. However, a zero trust network requires you to prove your identity every time you want to access something new. This is like needing a key for each room in the house, even if you're already inside.

The term "Zero Trust" was coined by Forrester Research analyst and thought-leader John Kindervag, and follows the motto, "never trust, always verify." His ground-breaking point of view was based on the assumption that risk is an inherent factor both inside and outside the network.

Zero trust security requires all users and all devices, whether in or outside the organisation's network, to be authenticated, authorised, and continuously validated against an access policy to check they meet security standards before being granted or keeping access to applications and data. This approach is particularly useful for modern businesses with no traditional network edge, using multiple hybrid cloud environments and with remote workers.

For users accessing services, trust must be built from user identity and behaviour, and device health, before they can access the service. The amount of confidence needed to trust a connection depends on the value of data being accessed, or the impact of the action being requested. If a connection does not satisfy the access policy, the connection is dropped.

Key Principles of Zero Trust Networks:

Know your architecture, including users, devices, services and data

To fully benefit from a zero trust approach, it's important to understand all parts of your system, including who uses it, the devices connected, the services you rely on, and where your data is stored. This knowledge helps you identify what's most important, spot potential risks, and avoid problems when trying to connect older systems that may not be compatible with zero trust.

Know your User, Service and Device identities

In a zero trust system, it's crucial to clearly recognise every user (people), service (software tasks), and device involved. Each must have a unique identity. Knowing exactly who or what is requesting access is key to deciding if they should be allowed to use certain data or services.

Assess your user behaviour, devices and services health

To maintain security in a zero trust system, it's essential to monitor how users behave and the condition of devices and services. These factors help determine how trustworthy your system is, making them crucial for setting security rules. For devices, this means ensuring they meet required standards, like having the latest updates installed or having security features like secure boot turned on. Tracking these aspects is key to keeping your system secure.

Use policies to authorise requests

In a zero trust system, every request for data or services should be approved based on specific rules, known as policies. These policies are the backbone of zero trust security, determining who gets access to what. They also allow for safe sharing of data or services with guest users or partner organisations while managing risks.

A key part of this system is the policy engine, which reviews various factors (or signals) and matches them with the access rules to decide if the request should be granted. This makes the policy engine a flexible and secure tool that adjusts based on what is being requested.

Authenticate & authorise everywhere

In a zero trust system, every connection to your data or services should be verified and approved, no matter where it comes from. This means checking multiple factors—like where the device is located, its condition, who the user is, and their current status—before allowing access. We take these precautions because we treat the network as untrustworthy and want to ensure that only properly verified connections are granted access.

Focus your monitoring on users, devices and services

In a zero trust system, your monitoring should primarily focus on users, devices, and services. By closely watching how these elements behave, you can assess their health and security. Monitoring should be tied to the policies you've set, ensuring that everything is configured correctly and working as expected. This shift in focus helps maintain the security and integrity of your system.

Don't trust any network, including your own

In a zero trust system, you should never trust any network, even your own. Always assume that the network between a device and the service it's accessing could be insecure. To protect your data, ensure that all communication over the network uses secure methods, so your information stays safe while being transmitted.

This approach also means rethinking how you handle traditional security measures like blocking harmful websites and phishing protection. These protections might need to be implemented differently in a zero trust setup.

Choose services designed for zero trust

Some services may not be compatible with zero trust and could require extra resources and effort to integrate, leading to more maintenance work. In these cases, it might be wise to explore other options that are specifically designed with zero trust in mind.

Choosing products that use standardised technologies can make it easier to connect and work smoothly with other services and identity providers.

Cyber Essentials aligns well with zero trust principles

The Cyber Essentials scheme provides a foundation of good cyber security practices that supports the principles of Zero Trust. Both approaches aim to reduce the risk of unauthorised access and breaches by ensuring secure configurations, strict access controls and timely security updates. While Cyber Essentials focuses on implementing basic protective measures, Zero Trust extends these principles to a more granular and continuous verification process for all users and devices and includes continuous protective monitoring.

Implementing the five technical controls of Cyber Essentials does not prevent an organisation using a zero trust architecture. Please see the [NCSC guidance](#) for more information.

© The IASME Consortium Ltd 2024 All rights reserved.

